C → D 인수인계 · Wazuh FIM 경보 연동 (S7 홈페이지 변조)

작성: 김상혁(C · shk12170-dev) · 2026-10-22 · 받는 사람: D(chacha1650a) · 기준: 10/21 실측·커밋 기록(PR #36) + 10/22 08:43 재확인

한 줄 요약	A의 최종 포털 VM(agent **010 haedam-portal-vm**)에서 파일이 바뀌면 C의 Wazuh가 실시간으로 잡고, **C PC의 연습용 Graylog**까지 1초 안팎에 도착하는 것을 확인했습니다. **D의 팀 Graylog로 보내는 연결은 아직 없습니다.** 오늘 이 연결과 S7 판정 규칙을 같이 만들고 싶습니다.
오늘 목표	① C manager → D Graylog 경보 수신 ② 파일 키·자산 맞추기 ③ S7 상관 규칙 초안(단, **보강 전 측정 뒤 활성화**) ④ 티켓 API·Wazuh API 방향 합의
구분	`실측` 직접 확인한 값 · `제안` 아직 시험하지 않은 설계

0. 오늘 아침 상태 (10/22 08:43 재확인) `실측`

항목	상태	시작 전 할 일
C Docker	Wazuh manager·indexer·dashboard, 수업 Graylog, n8n, MySQL 모두 실행 중. manager 설정(전송 블록 2개)은 재시작 뒤에도 유지	—
agent 010	**Disconnected** (마지막 연결 10/21 17:48:49). A VM이 꺼져 있거나 VPN 미연결로 추정	**A:** VM·VPN(team-a) 켜기 → C가 Active 확인
C 팀 VPN	**미연결** (10.250.0.3 없음, 유선 192.168.3.5만 있음)	**C:** team-c 연결. 010은 10.250.0.3으로 붙기 때문에 C VPN이 먼저 켜져 있어야 함
C 시계	NTP보다 **약 2.6초 빠름** (10/21 동기화 뒤 다시 어긋남)	**C:** Windows 시간 동기화. D PC도 확인 부탁
S7 판정 장치	C Graylog 이벤트 정의 15개 중 S7·FIM(010) 관련 **없음**, 117 워크플로 없음, FIM active response 없음	보강 전 측정 가능 상태 유지
보강 전 측정	**아직 안 함** (010의 마지막 FIM 경보는 10/21 16:47 복원 재시험)	**C·A:** D 규칙을 켜기 전에 실행

1. 현재 구성 (10/21 실측)

```
[A] VMware VM (haedam-portal)            [C] 내 PC · Docker Desktop              [D] PC
 포털 192.168.145.131:5000 (A PC NAT)      Wazuh manager 4.9.0                     팀 Graylog ─▶ n8n
 Wazuh agent 010 haedam-portal-vm ──VPN──▶ 10.250.0.3:1514/tcp  ──(오늘 연결)──▶  입력: 미정
 감시: /home/haedam/haedam-portal-frontend/dist        │
 VPN 10.250.0.2 (team-a)                               └─▶ C 연습 Graylog (gl-graylog:5514, 같은 PC 안)
```

항목	값	상태
Wazuh manager	C PC Docker Desktop, 4.9.0, 유선 192.168.3.5 / 팀 VPN **10.250.0.3**	**동작** `실측`
agent 목록	000 manager · 001 board-host(수업) · **010 haedam-portal-vm**(최종 포털 VM)	10/21 Active, VPN 경로 `10.250.0.2 → 10.250.0.3:1514` 확인 `실측` · 10/22 아침 Disconnected(위 0절)
예전 agent 009	haedam-portal-web(WSL, 이관 전). 증적 저장 후 **10/21 16:33 삭제**(팀장 승인)	**009는 쓰지 마세요.** 앞으로 기준은 010
감시 경로	`/home/haedam/haedam-portal-frontend/dist` (realtime, 해시·권한·diff 기록)	기준 스캔 5개: `index.html`, `favicon.svg`, `assets/index-C95-xzx9.js`, `assets/index-DhVbhBI5.css`, 시험 파일 1

Wazuh API	55000/tcp	**아직 닫혀 있음**(호스트 미공개), n8n용 계정 없음

2. 오늘 D가 해 주실 것: 경보 받는 입력

항목	권장값	이유
입력 종류	**Raw/Plaintext UDP**	Wazuh `syslog_output`은 UDP로만 보냄. 메시지가 `<132>… ossec: {JSON}` 모양이라 Syslog 입력은 JSON을 깨뜨릴 수 있음 실측
포트	D가 결정 (예: 5514/udp)	514/udp(pfSense), 5140(수업용)과 겹치지 않게
공개·허용	D PC 호스트에 포트 공개, **C 주소에서 온 것만 허용**	C 출발지는 VPN이면 10.250.0.3, LAN이면 192.168.3.5 → B와 경로 확정
스트림	`wazuh-alerts`: 규칙 "match input", **Default Stream에서 빼기** 체크	포털·pfSense 로그와 섞이지 않게

D가 알려 주실 것 → D PC 주소, 입력 포트. 받으면 C manager에 아래 블록을 추가하고 바로 시험 파일로 확인하겠습니다.

```
<syslog_output>
  <server>D PC 주소</server>
  <port>D 입력 포트</port>
  <format>json</format>
  <group>syscheck</group>   <!-- FIM 경보만 보냄. 다른 Wazuh 경보가 필요하면 말해 주세요 -->
</syslog_output>
```

3. 경보를 필드로 풀기 (수업 규칙 재사용) 실측

C 연습 Graylog에서 동작한 구성입니다. 파이프라인 `wazuh-parse`를 만들어 위 스트림에 연결하고 Stage 0·1에 넣으면 됩니다.

```
rule "wazuh: parse alert json"
when
  contains(to_string($message.message), "ossec: {")
then
  let m = regex("ossec: (.*)", to_string($message.message));
  let flat = to_map(flatten_json(to_string(m["0"]), "json"));
  set_fields(fields: flat, prefix: "wazuh_");
  set_field("wazuh_rule_level", to_long(flat["rule_level"]));
  set_field("source", to_string(flat["agent_name"]));
  set_field("message", concat(concat(concat("[Wazuh ", to_string(flat["rule_id"])), "] "), to_string(flat["rule_
description"])));
end

rule "wazuh: fim path safe"
when
  has_field("wazuh_syscheck_path")
then
  set_field("wazuh_file", replace(to_string($message.wazuh_syscheck_path), "\\", "/"));
end
```

헤맨 점 두 가지

- 파이프라인을 만들고 **Stage에 규칙을 넣지 않으면 오류 없이 아무 일도 안 일어납니다.**
- System → Configurations → Message Processors에서 **Pipeline Processor가 Message Filter Chain보다 뒤**에 있어야 스트림 연결이 적용됩니다.

4. 판정에 쓸 필드 (agent 010 실측)

필드	값·뜻	S7 용도
`wazuh_rule_id`	554 추가(level 5) · 550 변경(level 7) · 553 삭제(level 7)	변경 종류
`wazuh_syscheck_event`	added / modified / deleted	변경 종류
`wazuh_agent_id` · `wazuh_agent_name`	`010` · `haedam-portal-vm`	자산
`wazuh_file`	절대 경로. 예: `/home/haedam/haedam-portal-frontend/dist/zz_restoretest.txt`	**file_key 원천**
`wazuh_syscheck_sha256_after` / `_before`	바뀐 뒤·앞 해시(before는 변경 때만)	복구·정상 배포 판정
`wazuh_syscheck_mode`	`realtime`	—
`wazuh_timestamp`	경보 시각	10분 창·MTTD

5. S7 판정 규칙 초안 제안

조건: 같은 **자산** + 같은 **file_key**에서 ① FIM 추가·변경(554·550)과 ② 포털 `web.file_access` 성공 응답(2xx)이 **10분 안**에 모두 있으면 발동 (`card(signal_kind) > 1` , 기획서 합의본 ④ S7)

5-1. 파일 키·자산 맞추기 (규칙 예시, 미시험)

```
rule "S7: FIM file_key"
when
  has_field("wazuh_file")
  && starts_with(to_string($message.wazuh_file), "/home/haedam/haedam-portal-frontend/dist/")
  && (to_string($message.wazuh_rule_id) == "554" || to_string($message.wazuh_rule_id) == "550")
then
  set_field("file_key", replace(to_string($message.wazuh_file), "/home/haedam/haedam-portal-frontend/dist/",
""));
  set_field("asset_id", "haedam-portal");      // agent haedam-portal-vm ↔ 포털 ASSET_ID (D·A와 확정)
  set_field("signal_kind", "fim-change");
end
```

- 포털 이벤트는 `web.file_access` 의 `details.file_key` (GELF `file_key`)를 씀. 둘 다 **웹 루트 기준 상대 경로, `/` 구분**이어야 묶임 → 예: `assets/index-C95-xzx9.js`
- 홈페이지 `/` 접근을 `index.html` 로 기록할지는 B와 합의 필요(PR #20 코멘트)
- agent 이름을 앱 자산 ID로 **자동 간주하지 않기**로 함 → 대응표 한 줄로 명시

5-2. 빼야 할 경보 (중복 티켓·반복 대응 방지) 실측 근거

제외 대상	근거
553 삭제	복구 때 웹셸을 격리 폴더로 옮기면 553이 생김. S7 발동 조건이 아님

550인데 `sha256_after`가 기준본 해시 목록에 있음	복구·정상 배포 결과. 10/21 VM 복원 재시험에서 복원 경보의 `sha256_after` = 처음 해시(H0 `3fea661b…`), 변조 경보의 `sha256_before` = H0 확인
404 확인 요청	격리 뒤 효과 확인 접근은 2xx가 아니라서 자동 제외(2xx만 집계)

기준본 해시 목록을 A VM → D Graylog(lookup)로 옮기는 방법은 아직 미정입니다(GELF 재사용 또는 lookup 파일). 같이 정하고 싶습니다.

> ⚠ **규칙을 켜기 전에 꼭: 보강 전 1회 측정**
> 정량평가 문서 3절 1번(S7 규칙·117 없음 상태에서 공격 성공·로그만 남음)은 **한 번만** 할 수 있습니다. 10/21 확인 결과 C 쪽에는 S7 이벤트 정의·117 워크플로·FIM active response가 없었습니다. **측정이 끝났다고 C가 알릴 때까지 S7 이벤트 정의는 만들어만 두고 꺼 두세요(또는 알림 연결 없이).** 10/22 08:43 기준 측정 기록 없음(010의 마지막 FIM 경보 10/21 16:47).

6. 주의할 점

항목	내용
시각	Wazuh syslog 머리글의 시각은 **UTC**. 판정은 `wazuh_timestamp`나 Graylog `timestamp` 사용. C Windows 시계는 10/21 NTP로 맞춤(±0.005초). **A VM은 경보보다 3~5초 빠르게 기록됨** → D PC도 NTP 동기화 확인 부탁
지연·유실	경보 → C Graylog: 연습 20회 20/20 수신(대부분 0.35~1.25초), VM 3건 0.5~1.0초, 복원 재시험 4/4 수신. **UDP라서 VPN을 거칠 때 유실 건수도 같이 세야 함**
diff	VM agent에서는 바뀐 내용(diff)이 옴. 판정은 **해시로**, diff는 증적용
잡음	010은 PAM 로그인(5501/5502), sudo(5402), rootcheck(510), 디스크(531) 경보도 만듦 → `group syscheck`로 보내면 D에는 안 감
수업 설정	C의 수업 이벤트 정의 8번(웹셸 100220~100222)·n8n "7-Wazuh 경보봇"은 **게시판 경로에만** 반응. 팀 규칙과 섞지 않기

7. 다음 단계에서 같이 정할 것

주제	C 쪽 현황	D와 정할 것
117 파일 복구·격리	연습 환경 수동 복구·격리 통과(기준본은 웹 루트 밖·읽기 전용, 새 파일은 삭제 대신 격리, 해시로 확인). 자동화 스크립트는 다시 작성 필요	1안: n8n → C Wazuh API(55000) → agent 010 custom active response. 외부 입력 경로·셸 명령을 그대로 실행하지 않기
Wazuh API	55000 닫힘, 계정 없음	호출 주소(VPN), n8n 출발지만 허용, 최소 권한 계정. 비밀번호는 n8n 자격 증명에만
114 티켓 · 보안 대시보드	C 책임(인수인계). 사건 계약 `contracts/incident.schema.json` 기준으로 티켓 저장소·API를 C PC에 둘 계획	n8n 114가 보낼 API 주소·형식·인증. **모든 자리 티켓이 같은 곳으로** 가야 해서 이번 주 합의 필요
메모리	C PC 약 5.2/7.7GiB(Wazuh 전체 + 수업 Graylog + n8n + MySQL)	30분 동시 구동 시험(사전 위험 ③) 일정

8. 오늘 같이 할 순서 (제안)

1. **준비(A·C):** A VM·VPN 켜기, C VPN 연결, C 시계 동기화 → 010 **Active** 확인
2. **D:** 입력(Raw/Plaintext UDP)·스트림·파이프라인 만들고 **주소·포트** 알려 주기

3. **C:** manager에 팀용 `syslog_output` 추가 → A에게 `zz_` 시험 파일 하나 요청 → **D Graylog 수신·필드 확인** (554·550·553)
4. **C·A:** 보강 전 1회 측정 (S7 규칙 켜기 전)
5. **D·C:** file_key·asset 규칙, 제외 조건, 이벤트 정의 초안 → 측정 뒤 활성화
6. **D·C:** Wazuh API·117·114 티켓 API 방향 합의

> **완료 기준** — D Graylog에서 agent 010의 시험 파일 경보 3건 이상이 `wazuh_file` · `wazuh_syscheck_sha256_after` 필드와 함께 검색되고, 보낸 건수 = 받은 건수.

참고 자료

- PR #36: C 작업순서·작업일지·증적 — `docs/C-작업순서.md`, `work-log/members/shk12170-dev/2026-10-21.md`
- 증적: `docs/capstone/evidence/S07/` (README, agent 009 WSL 7건, agent 010 VM 3건, 복원 재시험 4건, 각 sha256)
- 정량평가 틀: `team_docs/정량평가-S7-shk12170-dev.md` · 기획서 합의본 ④ S7
- 이 문서에는 비밀번호·agent 키·API 키를 넣지 않았습니다.